

HW06 — API Testing Report

Sinh viên: 23127152 Nguyễn Tuấn Anh
Môn: Kiểm thử phần mềm — HW06 (AI-first API Testing)
SUT: EShop (`http://localhost:3000` , Node.js + Express + SQLite)
Công cụ: Postman · Newman 6.2.2 · newman-reporter-htmlextra · GitHub Actions
Ngày: 2026-08-19
Máy: Spartans-MB-Pro---C2F3HXFHW (Apple M3 Pro, macOS)
Repo: <https://github.com/yuran1811/hcmus-sw-testing--eshop-sut/tree/hw6/23127152> **Video:** <https://youtu.be/ZRuCA04ONK8>

1. Introduction

Bài tập yêu cầu pipeline kiểm thử API theo Bloom-AI: **generate → audit → extend → execute → report bugs**, kèm Postman/Newman, CI/CD, Agent Skill (G9.5) và AI Audit/Critique.

Ba API đã khóa (không trùng nhóm):

Pool	Feature	Endpoint(s)
A	FR-05 Product listing & search	GET <code>/api/products</code>
B	FR-11 Order history + detail	GET <code>/api/orders/my-orders</code> , GET <code>/api/orders/:id</code>
C	FR-15 Product management CRUD	POST/PUT/DELETE <code>/api/products</code>

Chi tiết Phase 0: [PHASE0_PLANNING.md](#) .

2. API Selection

Pool	Feature	Endpoint(s)	Rationale
A	FR-05 Product listing & search	GET <code>/api/products</code>	Public API; domain partitions trên search; bề mặt SEC-05 SQLi
B	FR-11 Order history + detail	GET <code>/api/orders/my-orders</code> , GET <code>/api/orders/:id</code>	Cặp JWT vs no-auth; kiểm IDOR / ownership / PII
C	FR-15 Product management CRUD	POST/PUT/DELETE <code>/api/products</code>	Admin CRUD theo spec; SEC-02/SEC-03

3. API 1 — Pool A (FR-05)

3.1 AI Generation Process

Sinh TC **từng bước** (skill `api-test-generate`), không một prompt chung:

Step	Nội dung	TC IDs
A Domain	Valid/invalid/boundary/charset/encoding cho search	TC-A1-001...018
B State	N/A state machine + 2 case idempotent GET	TC-A1-019...020
C Security	SEC-01...07, trọng tâm SEC-05 SQLi	TC-A1-021...030
D Schema	Content-Type, array root, fields/types, error ≠ HTML	TC-A1-031...040

Tổng AI: 40 TC (≥ 35) → [test-cases/API1 PoolA/generated.md](#) .

3.2 Audit Summary

Human audit (skill `api-test-audit`): **32 VALID / 3 INVALID / 5 INCOMPLETE** → [audit.md](#) .

Ví dụ sửa: pin hành vi `search=` rỗng (= list-all); expected SEC-05 viết theo **spec an toàn**, không theo SUT đang lỗi.

3.3 Extended Test Cases

6 TC manual (skill `api-test-extend`) → [extended.md](#) :

TC	Gap AI miss
TC-A1-E01...E04	URL-encoded / double-encoded SQLi; Content-Type trên lỗi
TC-A1-E03	Oracle so sánh số dòng baseline vs tautology
TC-A1-E05...E06	Sequence sau DROP probe; assert không có <h1>Database Error

Excel: [API1 PoolA.xlsx](#) .

3.4 Execution Results

Newman folder **API1 — FR-05** trên `http://localhost:3000` :

Metric	Value
Requests	20
Assertions	26
Passed	22
Failed	4

- HTML: [postman/reports/newman-api1-fr05.html](#)
- CLI: [postman/screenshots/newman-api1-fr05-cli.txt](#)
- Evidence header: [postman-prerequest.png](#) , [postman-console-x-student-id.png](#) , [newman-cli.png](#)

4 fail = SEC-05 (SQLi dump / HTML 500) — đúng kỳ vọng secure behavior.

3.5 Bugs Found

Bug	Severity	GitHub Issue	Evidence
BUG-PRODUCTS-001 SQLi search dumps catalog	Critical	#300	bug-reports/screenshots/BUG-PRODUCTS-001-sqli.json, issue-300-*.png
BUG-PRODUCTS-002 HTML 500 on bad SQL	Major	#301	BUG-PRODUCTS-002-body.html, issue-301-*.png

Author issues: **Anhnguyenk835**.

4. API 2 — Pool B (FR-11)

4.1 AI Generation Process

Steps A–D cho `my-orders` (JWT) + `GET /api/orders/:id` (no auth theo selection): domain token/id, compensating state (status visibility), SEC-02 + IDOR, schema.

Tổng AI: 40 TC → [API2 PoolB/generated.md](#) .

4.2 Audit Summary

34 VALID / 2 INVALID / 4 INCOMPLETE → [audit.md](#) .

Expected IDOR = **deny** (403/404), dù surface detail công khai theo selection.

4.3 Extended Test Cases

6 TC → [extended.md](#) : oracle PII `shipping_address` , horizontal IDOR với token A đọc đơn B, admin trên detail user, dual-actor compare, 401 JSON, count sau checkout.

Excel: [API2 PoolB.xlsx](#) .

4.4 Execution Results

Metric	Value
Requests	26
Assertions	35
Passed	30
Failed	5

- HTML: [newman-api2-fr11.html](#)
- CLI: [newman-api2-fr11-cli.txt](#)

4.5 Bugs Found

Bug	Severity	Issue	Evidence
BUG-ORDERS-001 IDOR + PII leak on GET <code>/api/orders/:id</code>	Critical	#302	BUG-ORDERS-001-idor.json, issue-302-*.png

5. API 3 — Pool C (FR-15)

5.1 AI Generation Process

Steps A–D cho POST/PUT/DELETE `/api/products` : domain (price > 0, name, ...), state (create→update→delete), SEC-02/SEC-03, schema.

Tổng AI: 40 TC → [API3 PoolC/generated.md](#) .

5.2 Audit Summary

33 VALID / 3 INVALID / 4 INCOMPLETE → [audit.md](#) .

Security expected = **401/403 theo spec**, không theo SUT hiện không có middleware.

5.3 Extended Test Cases

6 TC → [extended.md](#) : unauth mutate success-as-bug, user vs admin, impact chain list sau create, quirk `GET /api/products/:id` sau DELETE.

Excel: [API3 PoolC.xlsx](#) .

5.4 Execution Results

Metric	Value
Requests	22
Assertions	25
Passed	13
Failed	12

- HTML: [newman-api3-fr15.html](#)
- CLI: [newman-api3-fr15-cli.txt](#)

5.5 Bugs Found

Bug	Severity	Issue
BUG-ADMINPROD-001 CRUD thiếu JWT/admin	Critical	#303
BUG-ADMINPROD-002 Neg price / empty body accepted	Major	#304
BUG-ADMINPROD-003 DELETE missing id → 200	Minor	#305

Evidence: `bug-reports/screenshots/issue-303|304|305-*.png` + JSON/TXT dumps.

6. Postman Features Used

Feature	Cách dùng
Workspaces	Import collection + environment local
Collections	EShop-HW06.postman_collection.json (Setup, API1-3, Data-Driven, CI Smoke)
Variables / Environments	baseUrl, studentId, tokens, order/product ids
Pre-request scripts	Collection-level inject X-Student-Id: 23127152
Tests / assertions	Status, JSON schema, security oracles
Collection Runner + data file	products-search-data.csv → 8/8 pass
Examples / mock seed	postman/mock/fr05-list-example.json
Monitors	☐ — thay bằng GitHub Actions (Phase 5)

Phase 4 Newman:

Run	Result	Report
Data-driven FR-05	8 iter · 32 assert · 0 fail	<code>newman-report-data-driven.html</code>
Full collection	Failures = known Phase 1-3 bugs	<code>newman-report.html</code>

Chi tiết: [postman/PHASE4 NOTES.md](#) .

7. CI/CD Integration

Workflow: [.github/workflows/hw06-api-tests.yml](#)

Báo cáo đầy đủ: [CI CD Report.md](#)

Sample	Commit	Actions run	Screenshot
All pass	8b44b66	32269053058	cicd/screenshots/run-all-pass.png
One fail	2fe51ee	32269286455	cicd/screenshots/run-one-fail.png

CI Smoke (Must Pass) tách khỏi suite security (expected fail = bug evidence). Intentional fail chỉ đổi `ciExpectStatus` 200→201.

8. Agent Skill — AI Test Generator (G9.5)

Thiết kế generator (high-level): **Orchestrator** → **Generate** → **Audit** → **Extend** → **Execute** → **Bug report** (×3 API), rồi **CI/CD** → **Main report** → **G9.5 design**.

Artifact	Path
Architecture diagram (self-drawn Mermaid → PNG)	agent-skill/diagram.png
Mermaid source	agent-skill/diagram.mmd
Pseudocode + design	agent-skill/pseudocode.md
Working pipeline skills	.agents/skills/README-HW06.md

Pipeline skills (high-level): `generate` → **human review gate** (`api-test-audit`) → `extend` → `execute` → `bug-report` (×3), then `cicd` → `main-report` → `generator-design` .

9. Conclusion

Hạng mục	Số liệu
TC AI generated	120 (40×3)
TC manual extended	18 (6×3)
Bugs filed (GitHub)	6 (#300–#305, Anhnguyenk835)
Newman reports	API1/2/3 + full + data-driven + CI artifact
CI samples	1 green + 1 intentional red

Bài học: AI sinh nhanh domain/schema nhưng thiếu oracle cụ thể (row-count, PII field, Content-Type trên lỗi) và dễ nhầm “SUT đang trả 200” với expected. Human audit + extend security là bước bắt buộc trước khi tin Newman fail là bug thật.

Appendix

Document	Path
AI Audit Report	ai-audit/AI_Audit_Report.md
AI Critique	ai-audit/AI_Critique.md
Bug index	bug-reports/github_issues_links.md
Git commit log	git-commit-log.txt

Checklist	CHECKLIST.md
-----------	------------------------------